



Πανεπιστήμιο Πειραιώς
Σχολή Τεχνολογιών Πληροφορικής και Τηλεπικοινωνιών
Τμήμα Ψηφιακών Συστημάτων

Επίπεδο: Μεταπτυχιακό Πρόγραμμα Σπουδών

Ασφάλεια Ασύρματων και Κινητών Δικτύων

Android-Use Case 1

Επιβλέποντες Καθηγητές: Χρήστος Ξενάκης και Γεώργιος Ευθύμογλου
(Γρηγόριος Παπουτσής)

Καλαϊτζίδης Ιωάννης

ioannis_kalaitzidis@ssl-unipi.gr

Πειραιάς
04/05/2026

Περίληψη

Υλοποίηση ελέγχου ασφαλείας (penetration testing) και αντίστροφης μηχανικής σε δύο ευάλωτες εφαρμογές Android με στόχο τον εντοπισμό κρυμμένων flags. Η έρευνα περιελάμβανε ανάλυση μέσω του εργαλείου Apktool για την επιθεώρηση κρίσιμων αρχείων ρυθμίσεων και μέσω Android Studio για την εξερεύνηση του εσωτερικού συστήματος αρχείων. Μέσα από αυτή τη διαδικασία, αναδείχθηκε η κρίσιμη ευπάθεια της ανασφαλούς τοπικής αποθήκευσης, καθώς οι κωδικοί εντοπίστηκαν χωρίς καμία κρυπτογράφηση (plain-text). Συγκεκριμένα, τα flags ανακτήθηκαν με επιτυχία από τα προσωρινά αρχεία μνήμης SQLite (Write-Ahead Log) της πρώτης εφαρμογής και από τα αρχεία XML των Shared Preferences της δεύτερης.

Περιεχόμενα

Εισαγωγή.....	1
Πρακτικό κομμάτι εργασίας	2
Βιβλιογραφία	12

Εισαγωγή

Η παρούσα εργασία έχει ως στόχο την αξιολόγηση της ασφάλειας (Penetration Testing) σε εφαρμογές του λειτουργικού συστήματος Android. Για να επιτευχθεί αυτό, χρησιμοποιείται η τεχνική της αντίστροφης μηχανικής. Η αντίστροφη μηχανική είναι σαν να παίρνουμε ένα τελικό προϊόν -δηλαδή την έτοιμη εφαρμογή (αρχείο .apk)- και να το αποσυναρμολογούμε βήμα προς βήμα. Σκοπός αυτής της διαδικασίας είναι να δούμε τι κρύβεται στο εσωτερικό της εφαρμογής, πώς έχει γραφτεί ο κώδικάς της και πώς ακριβώς λειτουργεί, ώστε να εντοπίσουμε τυχόν αδυναμίες και κενά ασφαλείας. Η έρευνα και η ανάλυση επικεντρώνονται σε δύο συγκεκριμένες εφαρμογές (Enumeration02.apk και Enumeration03.apk) και χωρίζονται σε δύο βασικά στάδια:

- **1^ο στάδιο:** Με τη βοήθεια του εργαλείου **Apktool**, «ανοίγουμε» τα αρχεία της εφαρμογής. Αυτό μας επιτρέπει να επιθεωρήσουμε τα αρχεία ρυθμίσεων και τους πόρους της, αναζητώντας ευπάθειες, χωρίς να χρειαστεί να το εκτελέσουμε.
- **2^ο στάδιο:** Εγκαθιστούμε τις εφαρμογές σε ένα εικονικό κινητό μέσα από το περιβάλλον του **Android Studio**. Ενώ η εφαρμογή λειτουργεί, χρησιμοποιούμε το εργαλείο ADB (Android Debug Bridge) για να εισχωρήσουμε στο σύστημα αρχείων της συσκευής και να ελέγξουμε αν η εφαρμογή αποθηκεύει με ανασφαλή τρόπο ευαίσθητα δεδομένα, όπως για παράδειγμα σε τοπικές βάσεις δεδομένων (Databases) ή σε αρχεία ρυθμίσεων (Shared Preferences).

Συχνά, οι προγραμματιστές βασίζονται αποκλειστικά στην προστασία που παρέχει το ίδιο το λειτουργικό σύστημα (sandboxing) και παραλείπουν να κρυπτογραφήσουν τα δεδομένα που αποθηκεύουν τοπικά (όπως κωδικούς πρόσβασης). Αυτό αποτελεί κρίσιμο κενό ασφαλείας, το οποίο ένας επιτιθέμενος με φυσική πρόσβαση ή δικαιώματα διαχειριστή (root) στη συσκευή μπορεί εύκολα να εκμεταλλευτεί.

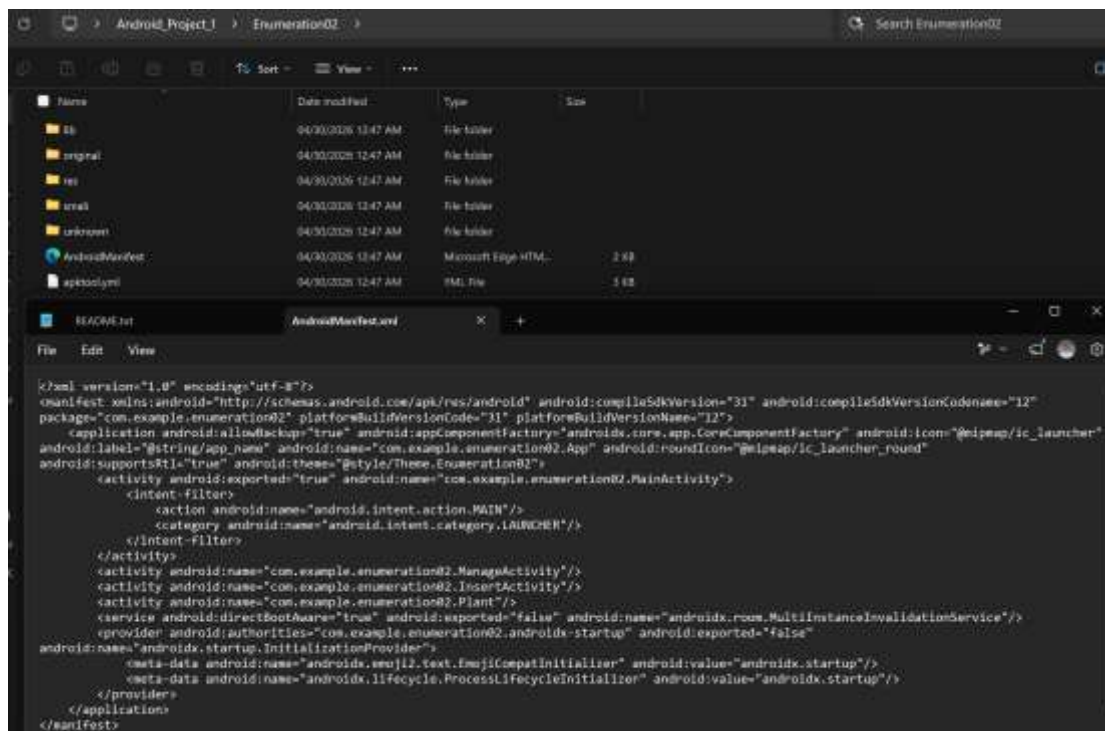
Πρακτικό κομμάτι εργασίας

Το πρώτο στάδιο της έρευνας περιλάμβανε την ανάλυση της εφαρμογής Enumeration02.apk. Καθώς τα αρχεία εγκατάστασης του Android (APK) είναι συμπιεσμένα, δεν ήταν δυνατή η απευθείας ανάγνωση των περιεχομένων τους. Για να παρακαμφθεί αυτό το εμπόδιο, χρησιμοποιήθηκε το εργαλείο ανοιχτού κώδικα **Apktool**. Μέσω της γραμμής εντολών (Command Prompt), εκτελέστηκε η εντολή αποκωδικοποίησης «**apktool d Enumeration02.apk**», η οποία ανέλαβε την αποσυναρμολόγηση της εφαρμογής. Η διαδικασία αυτή «ξεκλείδωσε» την εφαρμογή, δημιουργώντας έναν νέο φάκελο με όλα τα αρχεία του κώδικα και των ρυθμίσεων μεταφρασμένα πίσω στην αρχική τους μορφή. Από τον νέο αυτό φάκελο, η ανάλυσή μας επικεντρώθηκε στο κρισιμότερο αρχείο ρυθμίσεων του Android, το **AndroidManifest.xml**, το οποίο ανοίχτηκε σε απλό επεξεργαστή κειμένου για περαιτέρω μελέτη των δικαιωμάτων και των κρυφών στοιχείων της εφαρμογής.

```

C:\Users\Kalai>cd Desktop
C:\Users\Kalai\Desktop>cd Android_Project_1
C:\Users\Kalai\Desktop\Android_Project_1>apktool d Enumeration02.apk
I: Using Apktool 3.0.1 on Enumeration02.apk with 8 threads
I: Loading resource table...
I: Baksmaling classes.dex...
I: Decoding value resources...
I: Loading resource table from file: C:\Users\Kalai\AppData\Local\apktool\framework\1.apk
I: Decoding file resources...
I: Generating values XMLs...
I: Decoding AndroidManifest.xml with resources...
I: Copying original files...
I: Copying lib...
I: Copying unknown files...
C:\Users\Kalai\Desktop\Android_Project_1>

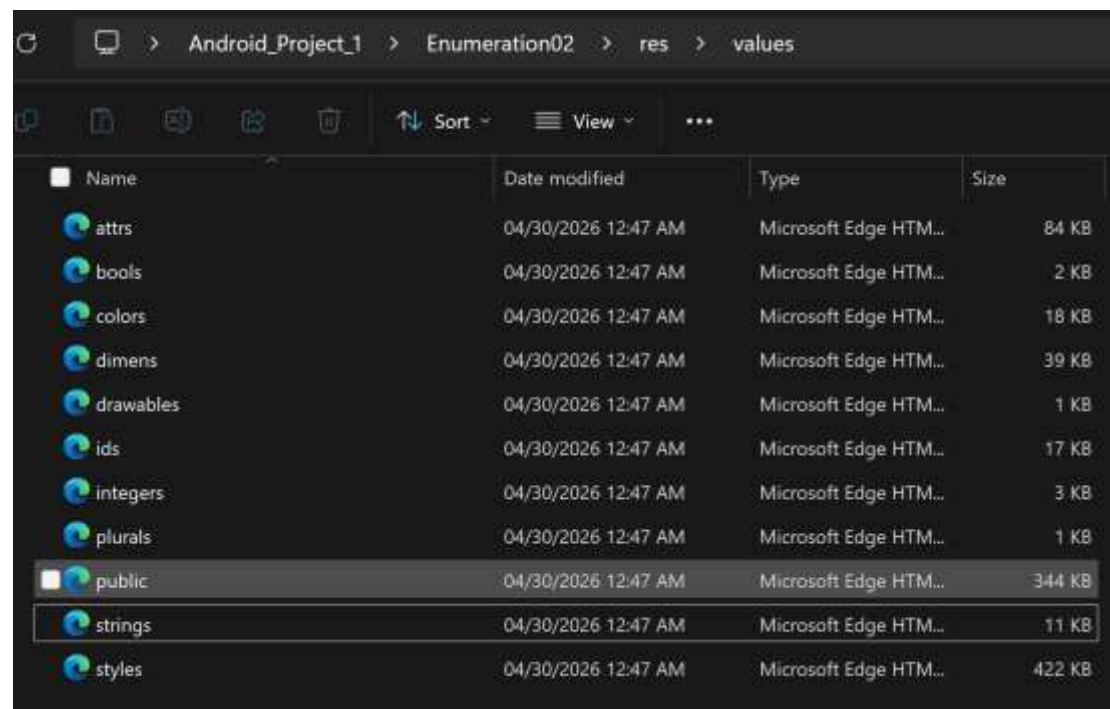
```



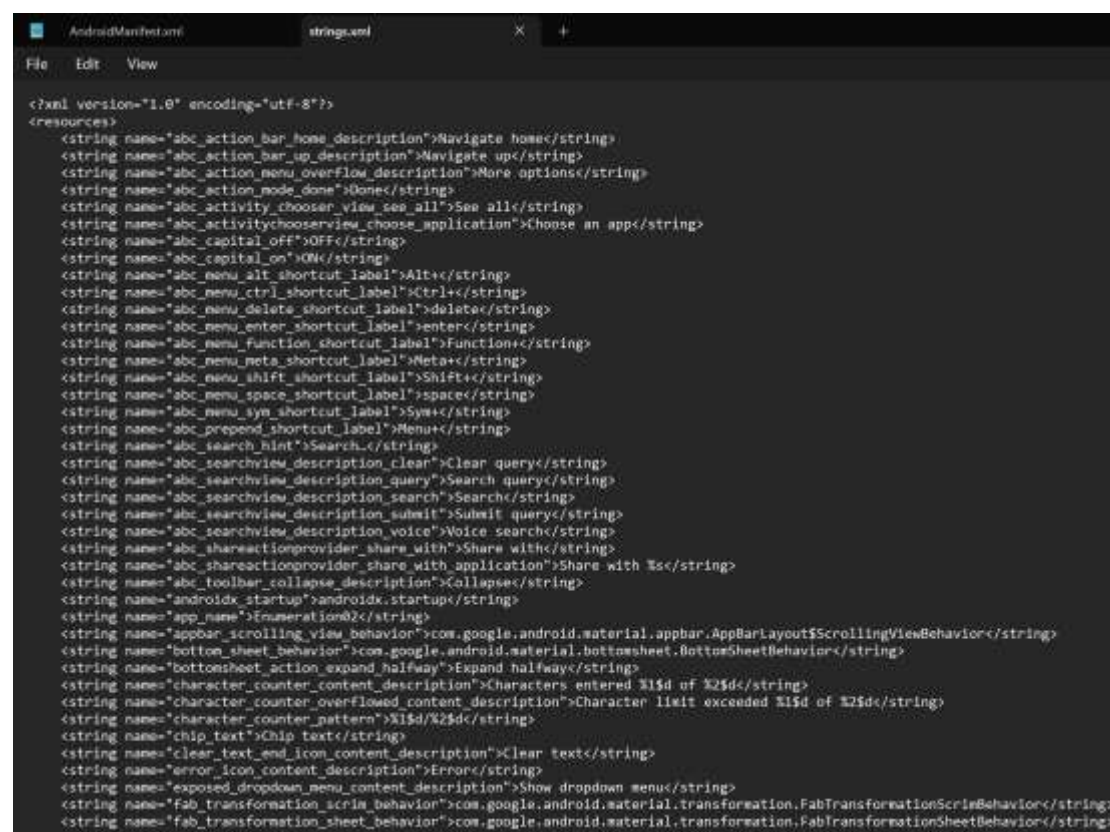
Στην αντίστροφη μηχανική, η ανάλυση ακολουθεί μια ιεραρχία, ξεκινώντας από τα αρχεία ρυθμίσεων όπου οι προγραμματιστές τείνουν να αφήνουν εκτεθειμένα δεδομένα. Αρχικά, εξετάστηκε το **AndroidManifest.xml**. Αν και το αρχείο δεν περιείχε κάποιο flag στα metadata του, η δομή του μας παρείχε μια κρίσιμη πληροφορία. Αποκαλύφθηκε η ύπαρξη των οθονών `InsertActivity` και `ManageActivity`. Αυτή η ονοματολογία υποδεικνύει έντονα τη χρήση κάποιας τοπικής βάσης δεδομένων (Database) στο παρασκήνιο της εφαρμογής.

Στη συνέχεια, ο έλεγχος μεταφέρθηκε στον κατάλογο των πόρων (resources) και συγκεκριμένα στο αρχείο **res/values/strings.xml**. Το αρχείο αυτό λειτουργεί ως το «λεξικό» της εφαρμογής και αποτελεί ένα κλασικό σημείο όπου οι developers ξεχνούν κωδικούς ή API keys. Και σε αυτή την περίπτωση, ο έλεγχος απέβη άκαρπος, καθώς

εντοπίστηκαν μόνο τυπικά κείμενα διεπαφής χρήστη (UI strings).



Name	Date modified	Type	Size
attrs	04/30/2026 12:47 AM	Microsoft Edge HTM...	84 KB
booleans	04/30/2026 12:47 AM	Microsoft Edge HTM...	2 KB
colors	04/30/2026 12:47 AM	Microsoft Edge HTM...	18 KB
dimens	04/30/2026 12:47 AM	Microsoft Edge HTM...	39 KB
drawables	04/30/2026 12:47 AM	Microsoft Edge HTM...	1 KB
ids	04/30/2026 12:47 AM	Microsoft Edge HTM...	17 KB
integers	04/30/2026 12:47 AM	Microsoft Edge HTM...	3 KB
plurals	04/30/2026 12:47 AM	Microsoft Edge HTM...	1 KB
public	04/30/2026 12:47 AM	Microsoft Edge HTM...	344 KB
strings	04/30/2026 12:47 AM	Microsoft Edge HTM...	11 KB
styles	04/30/2026 12:47 AM	Microsoft Edge HTM...	422 KB

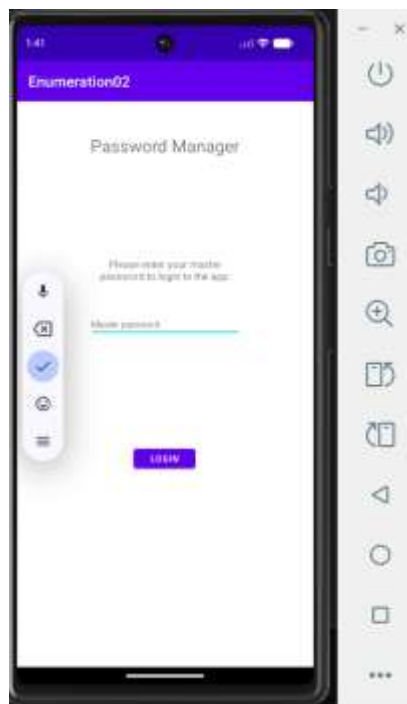


```
<?xml version="1.0" encoding="utf-8"?>
<resources>
    <string name="abc_action_bar_home_description">Navigate home</string>
    <string name="abc_action_bar_up_description">Navigate up</string>
    <string name="abc_action_menu_overflow_description">More options</string>
    <string name="abc_action_mode_done">Done</string>
    <string name="abc_activity_chooser_view_see_all">See all</string>
    <string name="abc_activitychooserview_choose_application">Choose an app</string>
    <string name="abc_capital_off">OFF</string>
    <string name="abc_capital_on">ON</string>
    <string name="abc_menu_alt_shortcut_label">Alt</string>
    <string name="abc_menu_ctrl_shortcut_label">Ctrl</string>
    <string name="abc_menu_delete_shortcut_label">delete</string>
    <string name="abc_menu_enter_shortcut_label">enter</string>
    <string name="abc_menu_function_shortcut_label">Function</string>
    <string name="abc_menu_meta_shortcut_label">Meta</string>
    <string name="abc_menu_shift_shortcut_label">Shift</string>
    <string name="abc_menu_space_shortcut_label">space</string>
    <string name="abc_menu_sym_shortcut_label">Sym</string>
    <string name="abc_prepend_shortcut_label">Menu</string>
    <string name="abc_search_hint">Search</string>
    <string name="abc_searchview_description_clear">Clear query</string>
    <string name="abc_searchview_description_query">Search query</string>
    <string name="abc_searchview_description_search">Search</string>
    <string name="abc_searchview_description_submit">Submit query</string>
    <string name="abc_searchview_description_voice">Voice search</string>
    <string name="abc_shareactionprovider_share_with">Share with</string>
    <string name="abc_shareactionprovider_share_with_application">Share with %s</string>
    <string name="abc_toolbar_collapse_description">Collapse</string>
    <string name="androidx_startup">androidx.startup</string>
    <string name="app_name">Enumeration02</string>
    <string name="appbar_scrolling_view_behavior">com.google.android.material.appbar.AppBarLayout$ScrollingViewBehavior</string>
    <string name="bottom_sheet_behavior">com.google.android.material.bottomsheet.BottomSheetBehavior</string>
    <string name="bottomsheet_action_expand_halfway">Expand halfway</string>
    <string name="character_counter_content_description">Characters entered %1$d of %2$d</string>
    <string name="character_counter_overflowed_content_description">Character limit exceeded %1$d of %2$d</string>
    <string name="character_counter_pattern">%1$d/%2$d</string>
    <string name="chip_text">Chip text</string>
    <string name="clear_text_end_icon_content_description">Clear text</string>
    <string name="error_icon_content_description">Error</string>
    <string name="exposed_dropdown_menu_content_description">Show dropdown menu</string>
    <string name="fab_transformation_scrim_behavior">com.google.android.material.transformation.FabTransformationScrimBehavior</string>
    <string name="fab_transformation_sheet_behavior">com.google.android.material.transformation.FabTransformationSheetBehavior</string>
```

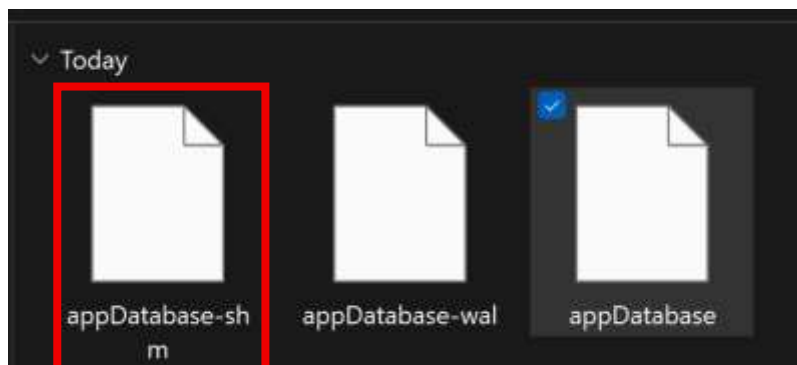
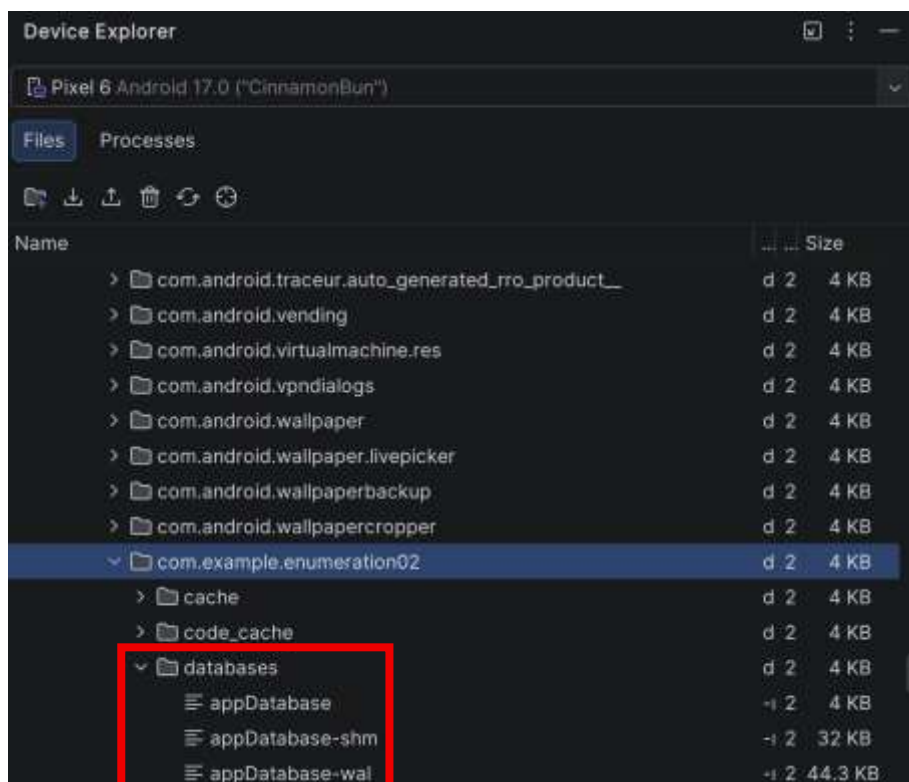
Δεδομένου ότι τα βασικά αρχεία ρυθμίσεων δεν αποκάλυψαν το flag σε μορφή απλού κειμένου και τα ευρήματα από το Manifest (ύπαρξη δραστηριοτήτων διαχείρισης δεδομένων) μας οδηγούν στο επόμενο βήμα. Η εφαρμογή θα εγκατασταθεί

και θα εκτελεστεί σε εικονικό περιβάλλον (Android Emulator), ώστε να ελεγχθεί ζωντανά ο τρόπος που διαχειρίζεται και αποθηκεύει τα δεδομένα της (2^ο στάδιο).

Η χρήση εικονικής συσκευής μας παρέχει τα απαραίτητα δικαιώματα (root) για πρόσβαση στα κρυφά αρχεία συστήματος. Αφού το αρχείο APK εγκαταστάθηκε και εκτελέστηκε, αποκαλύφθηκε ότι λειτουργεί ως Διαχειριστής Κωδικών (Password Manager), απαιτώντας ένα «Master password» για την είσοδο. Η λειτουργία αυτή επιβεβαιώνει την υπόθεση της αρχικής ανάλυσης (λόγω των InsertActivity και ManageActivity), καθιστώντας βέβαιο ότι η εφαρμογή χρησιμοποιεί κάποια τοπική βάση δεδομένων για να αποθηκεύει τους ευαίσθητους κωδικούς των χρηστών.



Για να ελέγξουμε τον τρόπο αποθήκευσης των κωδικών, χρησιμοποιήσαμε το εργαλείο Device Explorer του Android Studio. Πλοηγηθήκαμε στον κατάλογο του συστήματος (/data/data/), όπου η κάθε εφαρμογή αποθηκεύει τα τοπικά της δεδομένα (sandboxing). Εδώ αξίζει να σημειωθεί ότι ο φάκελος της βάσης δεδομένων δεν δημιουργείται αυτόματα κατά την εγκατάσταση του APK, αλλά μόνο αφού εκτελέσουμε την εφαρμογή και αλληλεπιδράσουμε μαζί της. Έχοντας ήδη εκτελέσει την εφαρμογή στο εικονικό περιβάλλον, εντοπίσαμε επιτυχώς τον φάκελό της (com.example.enumeration02) και διαπιστώσαμε την ύπαρξη του υποφακέλου databases. Όπως φαίνεται στην παρακάτω εικόνα, εκεί αποθηκεύεται μια τοπική βάση δεδομένων SQLite, η οποία αποτελείται από το κύριο αρχείο **appDatabase** και τα προσωρινά αρχεία καταγραφής (**appDatabase-shm** και **appDatabase-wal**). Ειδικότερα, η κατάληξη -wal στο αρχείο appDatabase-wal σημαίνει «Write-Ahead Log». Στο Android (και στις βάσεις SQLite γενικότερα), όταν μια εφαρμογή αποθηκεύει νέα δεδομένα, τα γράφει πρώτα σε αυτό το προσωρινό αρχείο, πριν τα περάσει οριστικά στο κεντρικό αρχείο της βάσης (appDatabase). Για να αναλυθεί το περιεχόμενό τους χωρίς τους περιορισμούς της συσκευής, τα αρχεία αυτά εξήχθησαν τοπικά στον υπολογιστή.

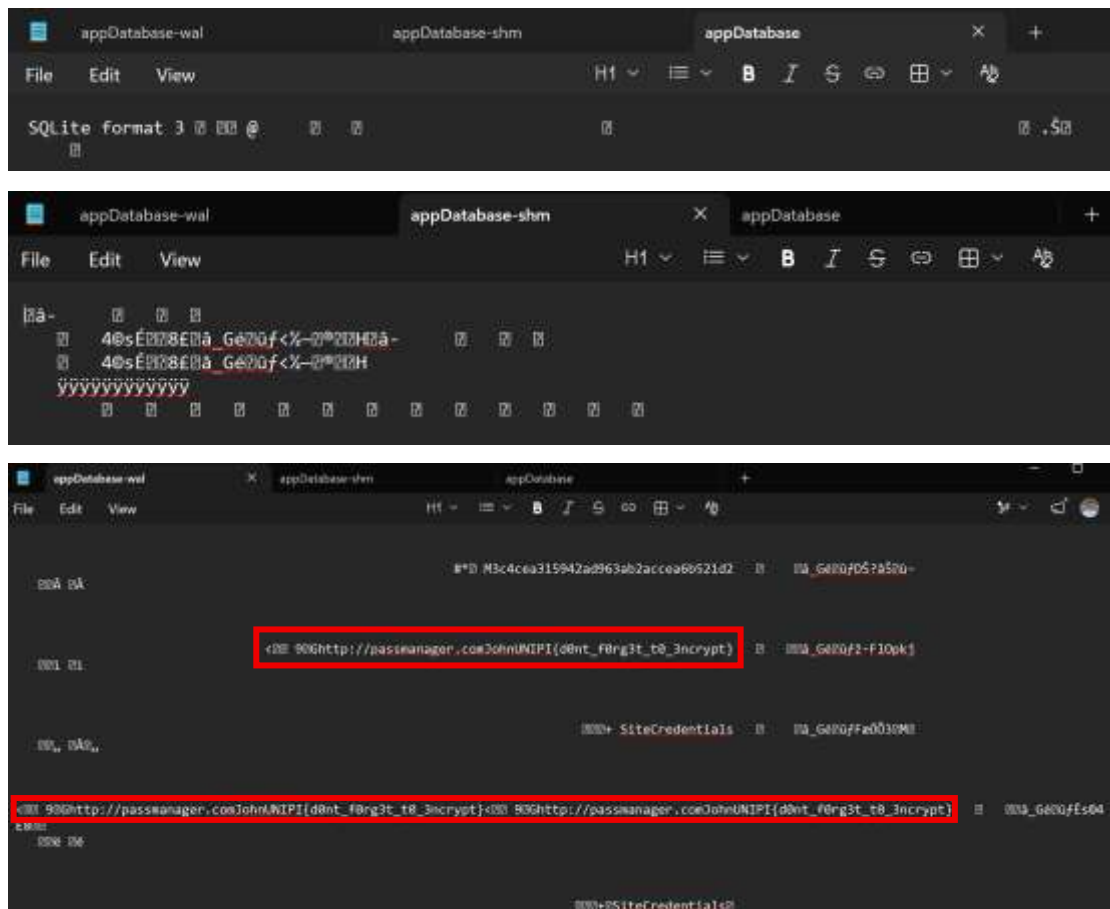


Μετά την εξαγωγή των αρχείων, το επόμενο βήμα ήταν η εξέταση του περιεχομένου τους. Προκειμένου να ελεγχθεί αν η εφαρμογή εφαρμόζει κάποια μέθοδο κρυπτογράφησης στα ευαίσθητα δεδομένα, τα αρχεία ανοίχτηκαν ως ακατέργαστα κείμενα (raw text) χρησιμοποιώντας έναν επεξεργαστή κειμένου (Notepad).

Κατά την επιθεώρηση του προσωρινού αρχείου καταγραφής appDatabase-wal (Write-Ahead Log), αποκαλύφθηκε ότι η εφαρμογή αποθηκεύει τα διαπιστευτήρια των χρηστών εντελώς απροστάτευτα. Όπως διακρίνεται στην εικόνα, ανάμεσα στα δυαδικά δεδομένα, εντοπίστηκε σε μορφή απλού κειμένου (plain-text) η εγγραφή για τον ιστότοπο (<http://passmanager.com>) με όνομα χρήστη John. Στο πεδίο του κωδικού πρόσβασης, αποκαλύφθηκε ξεκάθαρα το ζητούμενο flag: **UNIPi{d0nt_f0rg3t_t0_3ncrypt}**.

Η απουσία κρυπτογράφησης στην τοπική βάση δεδομένων επιτρέπει σε οποιονδήποτε επιτιθέμενο με φυσική πρόσβαση -ή πρόσβαση διαχειριστή (root)- στη

συσκευή, να υποκλέψει με τεράστια ευκολία όλους τους αποθηκευμένους κωδικούς του χρήστη. Επομένως με το flag ολοκληρώνεται με επιτυχία ο έλεγχος διείσδυσης (penetration test) για τη συγκεκριμένη εφαρμογή.



Η αξιολόγηση της δεύτερης εφαρμογής (Enumeration03.apk) ξεκίνησε ακολουθώντας την ίδια μεθοδολογία. Χρησιμοποιώντας το εργαλείο Apktool, πραγματοποιήθηκε αποκωδικοποίηση του αρχείου εγκατάστασης προκειμένου να

ελεγχθούν τα βασικά αρχεία ρυθμίσεων για τυχόν εκτεθειμένα δεδομένα.

```
Command Prompt
Microsoft Windows [Version 10.0.26200.8328]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Kalai>cd Desktop

C:\Users\Kalai\Desktop>cd Android_Project_1

C:\Users\Kalai\Desktop\Android_Project_1>apktool d Enumeration03.apk
I: Using Apktool 3.0.1 on Enumeration03.apk with 8 threads
I: Loading resource table...
I: Baksmaling classes.dex...
I: Decoding value resources...
I: Loading resource table from file: C:\Users\Kalai\AppData\Local\apktool\framework\1.apk
I: Decoding file resources...
I: Generating values XMLs...
I: Decoding AndroidManifest.xml with resources...
I: Copying original files...
I: Copying lib...
I: Copying unknown files...

C:\Users\Kalai\Desktop\Android_Project_1>
```

Αρχικά εξετάστηκε το αρχείο AndroidManifest.xml. Παρόλο που δεν εντοπίστηκε κάποιο flag, επιβεβαιώθηκε η δομή της εφαρμογής, καθώς εντοπίστηκαν ξανά οι δραστηριότητες (activities) ManageActivity και InsertActivity. Αυτό υποδεικνύει έντονα τη χρήση τοπικής βάσης δεδομένων στο παρασκήνιο. Στη συνέχεια, ελέγχθηκε το αρχείο πόρων res/values/strings.xml, το οποίο αποδείχθηκε επίσης «καθαρό».

```
AndroidManifest.xml
strings.xml

<?xml version="1.0" encoding="utf-8"?>
<manifest xmlns:android="http://schemas.android.com/apk/res/android" android:compileSdkVersion="11" android:compileSdkVersionCodename="12"
package="com.example.enumeration03" platformBuildVersionCode="11" platformBuildVersionName="12">
    <application android:allowBackup="true" android:appComponentFactory="androidx.core.app.CoreComponentFactory" android:icon="@mipmap/ic_launcher"
android:label="@string/app_name" android:name="com.example.enumeration03.App" android:roundIcon="@mipmap/ic_launcher_round"
android:supportRtl="true" android:theme="@style/Theme.enumeration03">
        <activity android:exported="true" android:name="com.example.enumeration03.MainActivity">
            <intent-filter>
                <action android:name="android.intent.action.MAIN"/>
                <category android:name="android.intent.category.LAUNCHER"/>
            </intent-filter>
        </activity>
        <activity android:name="com.example.enumeration03.ManageActivity"/>
        <activity android:name="com.example.enumeration03.InsertActivity"/>
        <service android:directBootAware="true" android:exported="false" android:name="androidx.room.MultiInstanceInvalidationService"/>
        <provider android:authorities="com.example.enumeration03.androidx-startup" android:exported="false"
android:name="androidx.startup.InitializationProvider">
            <meta-data android:name="androidx.emoji2.text.EmojiCompatInitializer" android:value="androidx.startup"/>
            <meta-data android:name="androidx.lifecycle.ProcessLifecycleInitializer" android:value="androidx.startup"/>
        </provider>
    </application>
</manifest>
```

```
strings.xml
File Edit View

<?xml version="1.0" encoding="utf-8"?>
<resources>
    <string name="abc_action_bar_home_description">Navigate home</string>
    <string name="abc_action_bar_up_description">Navigate up</string>
    <string name="abc_action_menu_overflow_description">More options</string>
    <string name="abc_action_mode_done">Done</string>
    <string name="abc_activity_chooser_view_see_all">See all</string>
    <string name="abc_activitychooserview_choose_application">Choose an app</string>
    <string name="abc_capital_off">OFF</string>
    <string name="abc_capital_on">ON</string>
    <string name="abc_menu_alt_shortcut_label">Alt+</string>
    <string name="abc_menu_ctrl_shortcut_label">Ctrl+</string>
    <string name="abc_menu_delete_shortcut_label">delete</string>
    <string name="abc_menu_enter_shortcut_label">enter</string>
    <string name="abc_menu_function_shortcut_label">Function+</string>
    <string name="abc_menu_meta_shortcut_label">Meta+</string>
    <string name="abc_menu_shift_shortcut_label">Shift+</string>
    <string name="abc_menu_space_shortcut_label">space</string>
    <string name="abc_menu_sym_shortcut_label">Sym+</string>
    <string name="abc_prepend_shortcut_label">Menu+</string>
    <string name="abc_search_hint">Search...</string>
    <string name="abc_searchview_description_clear">Clear query</string>
    <string name="abc_searchview_description_query">Search query</string>
    ...
Ln 1, Col 1 10,703 characters Plain text
```

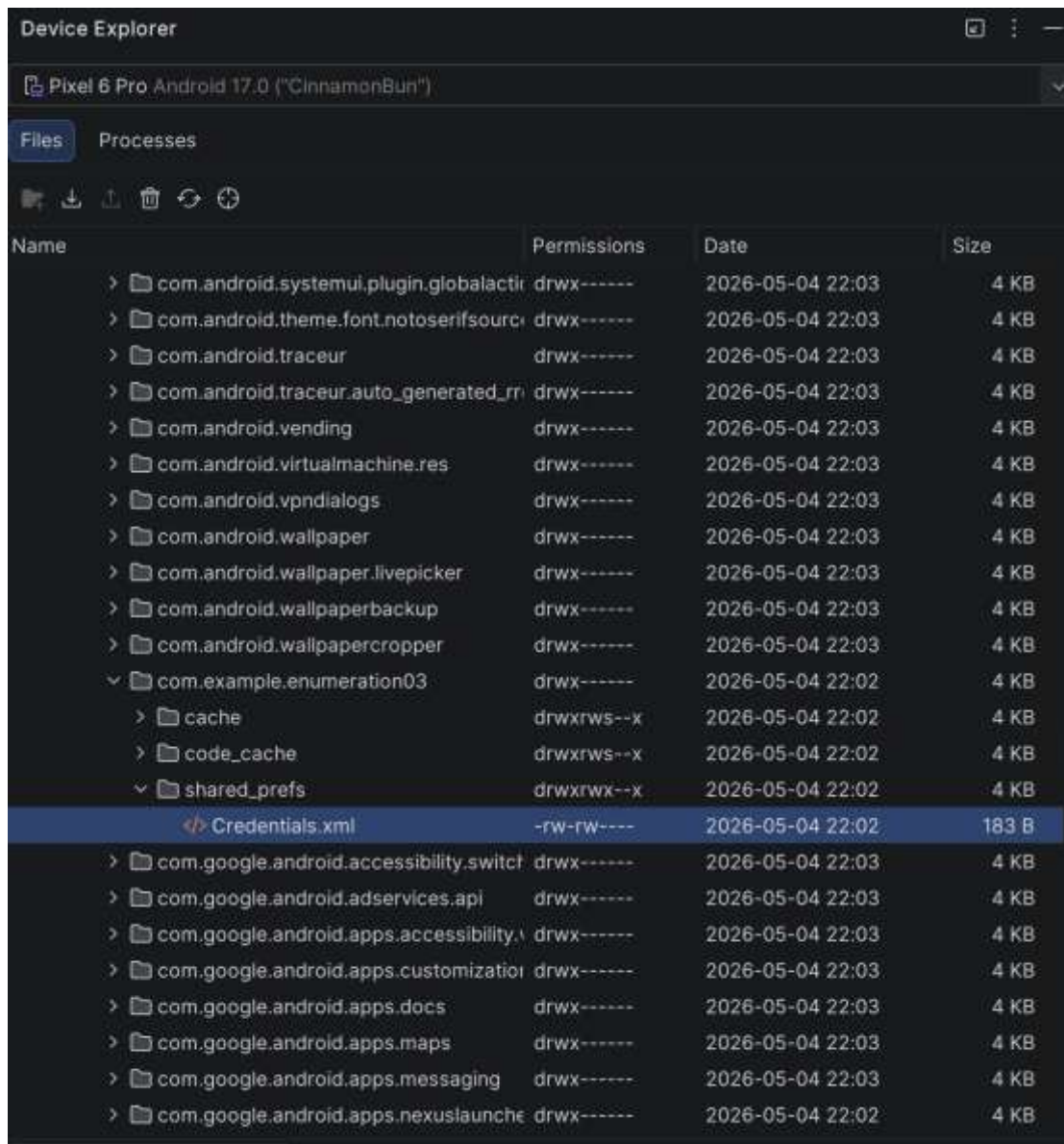
Δεδομένου ότι η ανάλυση δεν αποκάλυψε δεδομένα σε μορφή απλού κειμένου, το επόμενο λογικό βήμα είναι η μετάβαση στην εκτέλεση της εφαρμογής στο Android Studio, προκειμένου να ελεγχθεί ο τρόπος με τον οποίο η εφαρμογή διαχειρίζεται τα δεδομένα της σε πραγματικό χρόνο.

Η εφαρμογή Enumeration03.apk εγκαταστάθηκε και εκτελέστηκε. Η διεπαφή χρήστη (UI) επιβεβαίωσε την αρχική μας υπόθεση, ότι η εφαρμογή λειτουργεί ως Password Manager, όπως και στην προηγούμενη περίπτωση. Η ομοιότητα με την προηγούμενη εφαρμογή είναι εμφανής, γεγονός που μας οδηγεί να ελέγξουμε το σύστημα αρχείων της για να διαπιστώσουμε αν επαναλαμβάνει τα ίδια σφάλματα ανασφαλούς αποθήκευσης (Insecure Data Storage) ή αν χρησιμοποιεί κάποια άλλη, ίσως λίγο πιο «πονηρή» μέθοδο.



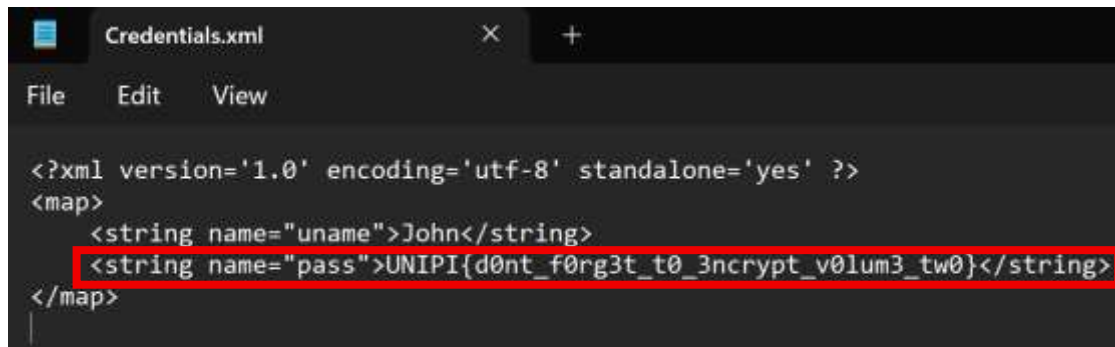
Ακολουθώντας τη διαδικασία της δυναμικής ανάλυσης, χρησιμοποιήσαμε ξανά το εργαλείο Device Explorer για να ερευνήσουμε το σύστημα αρχείων της εφαρμογής. Πλοηγηθήκαμε στον κατάλογο **/data/data/com.example.enumeration03**. Αυτή τη φορά, διαπιστώσαμε την απουσία του φακέλου databases. Αντίθετα, η

προσοχή μας στράφηκε στον φάκελο **shared_prefs** (Shared Preferences), ο οποίος αποτελεί ένα ακόμη σύνηθες σημείο αποθήκευσης ρυθμίσεων στο Android. Μέσα στον φάκελο εντοπίστηκε το αρχείο **Credentials.xml**.



Name	Permissions	Date	Size
> com.android.systemui.plugin.globalacti...	drwx-----	2026-05-04 22:03	4 KB
> com.android.theme.font.notoserifsource...	drwx-----	2026-05-04 22:03	4 KB
> com.android.traceur	drwx-----	2026-05-04 22:03	4 KB
> com.android.traceur.auto_generated_r...	drwx-----	2026-05-04 22:03	4 KB
> com.android.vending	drwx-----	2026-05-04 22:03	4 KB
> com.android.virtualmachine.res	drwx-----	2026-05-04 22:03	4 KB
> com.android.vpndialogs	drwx-----	2026-05-04 22:03	4 KB
> com.android.wallpaper	drwx-----	2026-05-04 22:03	4 KB
> com.android.wallpaper.livepicker	drwx-----	2026-05-04 22:03	4 KB
> com.android.wallpaperbackup	drwx-----	2026-05-04 22:03	4 KB
> com.android.wallpapercropper	drwx-----	2026-05-04 22:03	4 KB
✓ com.example.enumeration03	drwx-----	2026-05-04 22:02	4 KB
> cache	drwxrws--x	2026-05-04 22:02	4 KB
> code_cache	drwxrws--x	2026-05-04 22:02	4 KB
✓ shared_prefs	drwxrwx--x	2026-05-04 22:02	4 KB
Credentials.xml	-rw-rw----	2026-05-04 22:02	183 B
> com.google.android.accessibility.switc...	drwx-----	2026-05-04 22:03	4 KB
> com.google.android.adservices.api	drwx-----	2026-05-04 22:03	4 KB
> com.google.android.apps.accessibility...	drwx-----	2026-05-04 22:03	4 KB
> com.google.android.apps.customizatio...	drwx-----	2026-05-04 22:03	4 KB
> com.google.android.apps.docs	drwx-----	2026-05-04 22:03	4 KB
> com.google.android.apps.maps	drwx-----	2026-05-04 22:03	4 KB
> com.google.android.apps.messaging	drwx-----	2026-05-04 22:03	4 KB
> com.google.android.apps.nexuslaunche...	drwx-----	2026-05-04 22:02	4 KB

Το αρχείο εξήχθη στον τοπικό υπολογιστή και ανοίχτηκε με απλό επεξεργαστή κειμένου (Notepad). Όπως φαίνεται στην εικόνα, το αρχείο περιέχει τις εγγραφές για το όνομα χρήστη (uname="John") και τον κωδικό πρόσβασης. Για ακόμη μια φορά, τα δεδομένα είναι αποθηκευμένα σε μορφή απλού κειμένου (plain-text). Στη θέση του κωδικού βρέθηκε το ζητούμενο flag: **UNIPi{d0nt_f0rg3t_t0_3ncrypt_v0lum3_tw0}**.



```
<?xml version='1.0' encoding='utf-8' standalone='yes' ?>
<map>
  <string name="uname">John</string>
  <string name="pass">UNIFI{d0nt_f0rg3t_t0_3ncrypt_v0lum3_tw0}</string>
</map>
```

Η εφαρμογή παρουσιάζει την ίδια ακριβώς ευπάθεια με την προηγούμενη, αλλά υλοποιημένη με διαφορετικό μηχανισμό. Ο προγραμματιστής χρησιμοποίησε τα Shared Preferences αντί για βάση δεδομένων SQLite. Ο μηχανισμός αυτός είναι σχεδιασμένος αποκλειστικά για την αποθήκευση απλών ρυθμίσεων διεπαφής (π.χ. θέμα εμφάνισης, γλώσσα) και ποτέ για ευαίσθητα δεδομένα. Τα αρχεία XML που δημιουργούνται από τα Shared Preferences δεν προσφέρουν καμία εγγενή κρυπτογράφηση, καθιστώντας την υποκλοπή των κωδικών εξαιρετικά εύκολη σε περιπτώσεις παραβίασης της συσκευής.

Συμπέρασμα

Η παρούσα εργασία ανέδειξε με πρακτικό τρόπο τη σημασία του ελέγχου ασφαλείας (penetration testing) και της αντίστροφης μηχανικής σε εφαρμογές Android. Μέσα από τη χρήση του Apktool για αποσυναρμολόγηση και επιθεώρηση κώδικα και του Android Emulator για έλεγχο του συστήματος αρχείων, διαπιστώθηκε ένα κοινό λάθος, η εσφαλμένη αντίληψη της προστασίας. Πολύ συχνά, οι προγραμματιστές βασίζονται αποκλειστικά στον μηχανισμό απομόνωσης (sandboxing) του λειτουργικού συστήματος Android. Ωστόσο, όπως αποδείχθηκε και στις δύο υπό εξέταση εφαρμογές (Enumeration02 και Enumeration03), οποιοσδήποτε επιτιθέμενος αποκτήσει φυσική πρόσβαση ή δικαιώματα διαχειριστή (root) στη συσκευή, μπορεί άμεσα να παρακάμψει αυτούς τους περιορισμούς και να διαβάσει τα τοπικά αρχεία. Η απουσία κρυπτογράφησης σε ευαίσθητα δεδομένα, όπως οι κωδικοί πρόσβασης, τα αφήνει εκτεθειμένα σε μορφή απλού κειμένου (plain-text) -είτε αυτά βρίσκονται κρυμμένα σε προσωρινά αρχεία μνήμης βάσεων δεδομένων, είτε σε απλά αρχεία ρυθμίσεων.

Βιβλιογραφία

- HackerSploit. (2020, February 22). *Penetration Testing Bootcamp*. Retrieved from <https://www.youtube.com/watch?v=qJ9ZmkMvkcA>
- JohnHammond. GitHub - JohnHammond/security-resources: A communal outpouring of online resources for learning different things in cybersecurity. Retrieved from <https://github.com/JohnHammond/security-resources>
- David Bombal. (2021, May 5). *CTF Walkthrough with John Hammond* [Video file]. Retrieved from <https://www.youtube.com/watch?v=ZUqGSbvZp1k>
- OWASP MASTG - OWASP Mobile Application Security. Retrieved from <https://mas.owasp.org/MASTG/>
- OWASP Mobile Top 10 | OWASP Foundation. Retrieved from <https://owasp.org/www-project-mobile-top-10/>
- Data and file storage overview. Retrieved from <https://developer.android.com/training/data-storage>
- Save simple data with SharedPreferences. Retrieved from <https://developer.android.com/training/data-storage/shared-preferences>
- Write-Ahead logging. Retrieved from <https://sqlite.org/wal.html>